MacZine

THE MACTECH SOLUTIONS NEWSLETTER

ISSUE Nº 052 · OCTOBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

ARGUMENT · CONTINUOUS POSTURE

DoD Retired the Snapshot for Its Own Systems. CMMC Kept It.

The DoD CIO's risk management construct ended snapshot-in-time authorization for DoD systems. Contractor CMMC posture should follow, verifiably.

BY **PATRICK CARUSO**

READING TIME · 6 MIN

CMMC · CSRMC · CONTINUOUS-MONITORING · SPRS · SELF-ATTESTATION

In September 2025 the Department of Defense CIO published a one-page diagram that quietly retired the snapshot. The Cyber Security Risk Management Construct replaced the Risk Management Framework as the way the Department manages risk on its own systems, and the Department's announcement put the change in four words: from "snapshot in time" assessments to "dynamic, automated, and continuous" risk management. Systems are onboarded into continuous monitoring, watched through real-time dashboards and alerts, and held in a standing authorization posture instead of being re-papered on a calendar.

A year later the contractor side of the house has gone the other direction. CMMC Phase II was suspended on 13 July 2026, and a class deviation on 3 September made the suspension binding, directing contracting officers to strip third-party assessment requirements from contracts. What remains is the self-assessment, the score posted to SPRS, and a senior official's annual affirmation. For the Defense Industrial Base, the snapshot is no longer one input to a system. For now it is the system.

FIELD COPY
ISSUE Nº 052
CMMC

Sep 2025

WHEN THE DOD CIO REPLACED SNAPSHOT-IN-TIME AUTHORIZATION OF ITS OWN SYSTEMS WITH THE CYBER SECURITY RISK MANAGEMENT CONSTRUCT

The Department has already written down why snapshots fail

The construct is unusually direct about its purpose. It exists to "produce a culture, mindset and process that reimagines cyber risk management to be faster in keeping with the rate of change; more effectively assesses and conveys risk; and is less burdensome." Its five phases end in Operations, where the system is accepted for continuous monitoring and run on a "repeatable playbook to manage real-time risk monitoring via automated dashboards and alerts," with high risk elevated to someone who can act on it.

None of that is exotic. It is the observation every assessor makes on the first day of fieldwork: a posture described once, in a document, starts aging the moment the document is signed. Configurations drift, people leave, a register goes unattended for a quarter. A snapshot does not lie about the day it was taken. It is simply silent about every day after.

10

STRATEGIC TENETS IN THAT CONSTRUCT, AMONG THEM CONTINUOUS MONITORING, AUTOMATION AND RECIPROCITY

The pause made the snapshot carry more weight, not less

Remove the third-party assessment and the self-attested number has to carry everything a C3PAO would have checked. It carries legal weight too. Inflated self-scores have already produced False Claims Act settlements, one of roughly $500,000 in June 2026 according to press reports, and the official who affirms the score is the one whose signature is on it.

The Department knows where the gap is. According to press reports of the DoD CIO's remarks on 9 September 2026, the assessor community's concerns about the pause centered on how the Department would confirm compliance at all. The Department's own description of its CMMC review speaks of "replacing bureaucratic compliance with scalable, resilient cybersecurity measures." The Reform Task Force's recommendations, due 11 September, have not been published. Nobody outside the Department knows what comes next, and anyone who claims to is selling something.

1

SCORE A CONTRACTOR POSTS TO SPRS AND AFFIRMS EACH YEAR, HOWEVER ITS EVIDENCE MOVED IN BETWEEN

What is knowable is the shape of a better answer, because the Department drew it for its own systems.

What a point-in-time number cannot carry

Take the SPRS score a prime is handed today. It is one integer. It does not say what evidence produced it, when that evidence was last observed, or what the number was last quarter. It cannot be checked by the prime without asking the supplier to produce the same evidence again, which is why every prime asks, and why every supplier answers the same questions once per customer. The construct has a tenet for exactly this waste, reciprocity: "accept each other's assessed security posture to share information." A screenshot of a score is not an assessed posture anyone can accept. It is a claim.

Four properties of a posture record worth trusting

Apply the construct's principle to a contractor enclave and four requirements fall out.

It is continuous. The score is recomputed by the same DoD Assessment Methodology every time the evidence behind it changes, not once a year. Every one of the 320 NIST SP 800-171A assessment objectives cites the evidence that supports it, by hash and by the time it was observed.

It keeps its history. Every past value stays. A posture that improved from 75 to 89 should be able to show the morning it was 75 and what changed, and a posture that slipped should not be able to hide the slip under this week's number.

It is tamper-evident. History that lives in an editable database is a story, not a record. Append-only storage, a hash chain, and signed checkpoints mirrored somewhere public turn it into a record: rewriting the past breaks a signature someone else already holds.

The person relying on it can check it without trusting the vendor. A prime should be able to open a link, verify the signature against a public key, and confirm the history matches the published checkpoints, in its own browser. And the record should say plainly what it does not prove, which is that the evidence itself is accurate. That part is still the assessor's job.

◆ WHAT "TAMPER-EVIDENT" MEANS IN PRACTICE

Every change to the score and to each control's adjudication is appended to a ledger that cannot be edited, each entry chained to the last by hash. Periodically the state of that ledger is signed and copied to a public repository that others can clone. Rewriting a past value would then fail to match a checkpoint someone else already holds. That is a weaker promise than "immutable" and a much stronger one than "trust us", and it is the honest word for it.

Where the construct stops

Precision matters here, because this space is full of borrowed authority. The Cyber Security Risk Management Construct governs DoD systems connected to the DoD Information Network. It does not apply to contractors. Contractors do not hold an authorization to operate, continuous or otherwise. A continuously maintained self-assessment record is not a CMMC certification, and the Department has said nothing about whether it would ever accept one in place of an assessment. The score you post to SPRS is still the score you post to SPRS.

The argument is narrower and, I think, harder to dismiss: the Department has concluded that a snapshot is the wrong instrument for understanding cyber risk on its own systems. The same conclusion holds for the contractor posture the Department relies on, and while third-party assessment is suspended, the contractor's own record is the only instrument there is. It should be the best record the contractor can produce.

What we built, and what it is not

MacTech is a defense contractor that handles CUI, so we built this for our own enclave first and publish its numbers, with dates, on our proof page. The engine recomputes the SPRS methodology score as evidence arrives from the enclave, keeps the history append-only in a hash-chained ledger, and produces an assessment binder that checks itself offline. The last step, signing checkpoints of that ledger to a public mirror so a customer can hand a prime a link the prime verifies in its own browser, is built and switches on when our signing key is issued. It does not certify anyone, it is not endorsed by the Department, and it does not change what you owe in SPRS.

The Department retired the snapshot for its own systems a year ago. The rest of us do not need to wait for a rule to do the same. ◆